

ASSET MANAGEMENT POLICY

Version 1.0

Revision Date: July 23, 2026

Contact: security@prompthalo.com



DOCUMENT INFORMATION

Document Family	Operations and Resilience
Document Title	Asset Management Policy
Document ID	POL-AM-001
Current Version	1.0
Approved Date	July 23, 2026
Approved By	Information Security Steering Committee
Effective Date	July 23, 2026
Document Owner	Chief Executive Officer — Accountable Party
Prepared By	Security Officer
Review Cycle	Annual, or upon significant change to systems, threats, or obligations
Supersedes	N/A
Audience	All personnel and contractors who hold, use or administer Company assets
Next Review Date	July 23, 2027
Classification	Internal

APPROVALS

Name	Information Security Role	Signature	Date
Madhuri Chandoor	CEO and Founder		July 23, 2026
Praveen Sharma	Security Officer		July 23, 2026

COMPLIANCE

This document supports the SOC 2 Trust Services Criteria CC2.1 (Information Quality), CC6.4 (Physical Access), CC6.5 (Asset Disposal), CC6.8 (Malicious Software Prevention) and CC7.1 (Vulnerability Detection). Where the Company processes protected health information or personal data on behalf of clients, it also supports HIPAA Security Rule 45 CFR §164.310(c) and §164.310(d), and GDPR Articles 5, 17, 30 and 32.

DOCUMENT VALIDITY

This document is valid only in its published electronic form in the PromptHalo Technologies policy repository. Printed or locally saved copies are uncontrolled and must be verified against the published version before use. This document is classified Internal and may not be distributed outside PromptHalo Technologies or its authorised clients without the written approval of the Security Officer.

TABLE OF CONTENTS

1 OVERVIEW AND PURPOSE	5
2 SCOPE	5
3 ROLES AND DEFINITIONS.....	5
4 TERMINOLOGY	5
5 ASSET INVENTORY.....	6
6 ENDPOINT CONFIGURATION AND PROTECTION	7
7 PERSONALLY OWNED DEVICES	8
8 CLOUD AND EPHEMERAL ASSETS	8
9 SOFTWARE, SAAS AND SHADOW IT	9
10 MEDIA HANDLING AND SECURE DISPOSAL.....	9
11 ASSET RETURN AND OFFBOARDING	10
12 ASSET RECORDS AND EVIDENCE.....	10
13 ENFORCEMENT.....	10
14 EXCEPTIONS.....	11
15 REFERENCE.....	11
16 DOCUMENT POLICY HISTORY.....	11

1 Overview and Purpose

PromptHalo Technologies (“the Company”) maintains a practical record of the assets and services it relies upon so that access, ownership, protection and disposal can be managed appropriately. This policy is designed for the Company’s current size and risk profile and uses proportionate controls, including provider records, access controls, personnel attestations and maintained lists where automated tooling is not available. It does not require intrusive monitoring of personally owned devices unless a specific customer, legal or risk requirement makes a managed device necessary.

2 Scope

This policy applies to **Company-controlled systems, cloud resources, SaaS services, code repositories, data stores and other assets** used to provide Company services. Personally owned devices are in scope only to the extent that they are used to access Company systems or information. The Company does not assume ownership or general administrative control of a person’s private device.

3 Roles and Definitions

1. “The Company” refers to PromptHalo Technologies.
2. The CEO or, in their absence, the Security Officer (the “Accountable Party”) owns this policy, oversees its implementation and enforcement, and may delegate specific duties to a designee. [SOC 2: CC1.3]
3. The Information Security Steering Committee approves this policy and reviews it at least annually. [SOC 2: CC1.2, CC5.3]

4 Terminology

The following terms have the meanings given below wherever they appear in this policy.

1. **Accountable Party** — the CEO or, in their absence, the Security Officer, who owns this policy.
2. **Asset** — anything the Company relies upon to deliver its service or that holds Company or client information, including endpoints, cloud resources, SaaS subscriptions, code repositories, data stores, model artifacts and agents.
3. **Asset owner** — the named individual accountable for an asset’s configuration, protection and eventual disposal.
4. **BYOD** — a personally owned device used for Company or client work.
5. **Confidential information** — information classified Confidential or Restricted under the Data Classification Policy, including customer data.
6. **Control** — an activity, automated or manual, performed on a defined cadence that produces evidence it occurred.
7. **Deficiency** — a control that is absent, not operating as described, or not producing evidence.

8. **Endpoint** — a laptop, desktop or mobile device used to access Company or client information, whether Company-owned or personally owned.
9. **Ephemeral asset** — a cloud resource created and destroyed automatically, which exists between scheduled inventory runs.
10. **Information Security Steering Committee** — the Company's oversight body for information security. At the Company's current size, the Committee comprises the CEO, and every reference in this policy to a decision, approval, review or report of the Committee is satisfied by a dated written record made or confirmed by the CEO; a formal meeting is not required. [SOC 2: CC1.2, CC1.3]
11. **Inventory** — the authoritative record of assets, assembled from the systems that create them rather than maintained by hand.
12. **Model artifact** — a set of model weights, a container image or a fine-tuned derivative held or run by the Company.
13. **Personnel** — employees, officers, contractors, consultants, interns and temporary workers of the Company.
14. **Sanitization** — rendering information on media irrecoverable before the media leaves Company control or is reused.
15. **Security Officer** — the individual accountable for day-to-day operation of the security program.
16. **Shadow IT** — a service or application adopted for Company work without passing through the approval process.
17. **Significant change** — a change meeting the trigger criteria in the Risk Management Policy that requires risk reassessment.
18. **Subservice organization** — a third party whose controls the Company relies upon and which is carved out of the Company's report.

5 Asset Inventory

1. The Company shall maintain a reasonable inventory of material assets used to operate the service, including cloud accounts and resources, SaaS subscriptions, code repositories, data stores, domains and certificates, and material model or agent services. Personally owned devices may be recorded at a minimum by user and device type where they are used to access Company systems. [SOC 2: CC2.1]
- The inventory shall use records already available from the Company's cloud, identity, code-hosting and SaaS providers where practical. A maintained list may be used where automated information is unavailable. The Company is not required to purchase or deploy a particular asset-management or endpoint-monitoring product solely to satisfy this policy. [SOC 2: CC2.1]
2. The inventory shall be assembled, so far as the Company's tooling allows, from the systems that create assets — the cloud provider, the identity provider, the code host and whatever device agent

the Company operates. Where a category has no such source, a single maintained list is sufficient. What the policy requires is one inventory, not a particular means of producing it. [SOC 2: CC2.1]

3. An asset without an owner shall be investigated and either assigned or decommissioned. [SOC 2: CC2.1, CC1.3]
4. The inventory shall be reconciled against its sources and the current personnel list at least annually, and on each joiner or leaver. Where nothing has changed, that shall be recorded. Discrepancies shall be investigated rather than corrected silently. [SOC 2: CC2.1, CC6.8]
5. Assets holding information classified Confidential or Restricted shall be identified as such in the inventory, so that protection requirements can be applied and evidenced. [SOC 2: CC2.1, C1.1 · GDPR Art. 30, 32]
6. **Model artifacts and agents** are assets and appear in the inventory on the same terms, recording the owner, the provider or source, the version in use and the highest data classification permitted. Their evaluation, approval and retirement are governed by the AI Governance Policy and are not restated here. [SOC 2: CC2.1, CC9.2]
7. Where a change moves the system boundary, closing that change includes updating the inventory and the System Security Plan. [SOC 2: CC3.4, CC2.1]

6 Endpoint Configuration and Protection

The Company therefore protects information through the cloud services that hold it and the accounts that reach it, rather than through the device.

1. The Company runs no device management platform, no endpoint detection software and no agent of any kind on personal devices, and does not necessarily intend to. Nothing in this policy requires a person to install Company software on a device they own, or to permit the Company to inspect it. [SOC 2: CC6.8, CC2.1]
2. The Company keeps a simple list of who works for it and, for each person, the devices they use for Company work — make and operating system is enough. The list is confirmed by each person when they join and at the annual acknowledgment. No agent, scan or inventory tool produces it. [SOC 2: CC6.8, CC2.1, CC6.1 · HIPAA §164.310(c)]
3. Personnel are asked to keep the protections their own device already offers switched on: disk encryption, a screen lock, and automatic operating system and browser updates. These come with the operating system, cost nothing and need no Company involvement. Each person confirms them once a year in the same acknowledgment. [SOC 2: CC6.8, CC6.4, CC6.7 · HIPAA §164.312(a)(2)(iv), as applicable]
4. The device list is checked once a year against the list of people currently engaged, to catch a person who has left and a person whose devices were never recorded. Where nothing has changed, that is recorded and the check is complete. [SOC 2: CC6.8, CC2.1]
5. Where a client agreement expressly requires managed or monitored endpoints, the Company shall provide equipment for that work rather than impose the requirement on a personal device. If the

Company is unwilling to provide equipment, it shall decline the requirement rather than accept it and leave it unmet. [SOC 2: CC6.8, CC6.1]

6. What a person installs on their own device is their business. Personnel are asked only to use licensed software for Company work and not to install anything that would capture or forward Company or client information. Where the Company issues equipment, it manages that equipment itself. [SOC 2: CC6.8, CC6.3]

7 Personally Owned Devices

Personnel bring their own laptops and phones. The Company requires a security baseline on those devices and, in return, limits what it collects from them. Both halves are necessary for the arrangement to hold.

1. Personnel use their own laptops, tablets and phones. The Company protects information by controlling where it is kept and who can reach it, not by controlling the device. [SOC 2: CC6.4]
2. Work is done in the Company's cloud services, so information stays there rather than on anyone's machine. Where a file has to be downloaded to get the work done, it is deleted when it is no longer needed and at the end of the engagement. [SOC 2: CC6.5, CC6.7 · GDPR Art. 5(1)(c)]
3. Information classified Restricted is handled only on equipment the Company provides. [SOC 2: CC6.1, CC6.4]
4. The Company does not monitor personal devices and collects nothing from them. The only record it holds is the device list described in the previous section, which each person supplies themselves. [SOC 2: CC2.2, C1.1 · GDPR Art. 13]
5. If a device is lost or stolen, or a password may have been exposed, tell the Security Officer within a day. The Company will sign the accounts out and reset the credentials. It will not wipe a personal device, and because the work lives in the cloud services there is nothing on the device to wipe. [SOC 2: CC7.4, CC6.5 · GDPR Art. 33]
6. When an engagement ends, access is switched off, the person is removed from the device list, and they confirm they have deleted any Company files still on their machine. That confirmation is kept with the offboarding record. [SOC 2: CC6.5, CC6.3 · HIPAA §164.310(d)(2)]

8 Cloud and Ephemeral Assets

Cloud resources are created and destroyed faster than a hand-kept list can follow, so the provider's own records are the inventory and tagging is what makes ownership legible.

1. Cloud-provider records shall be used as the primary source for cloud assets where available. The Company shall review material cloud assets periodically and after significant changes; continuous discovery tooling is not required unless justified by risk or contractual obligation. [SOC 2: CC2.1, CC7.1]
2. Resources shall carry tags identifying the owner, the environment and the data classification. Untagged resources in production shall be raised as a finding and either tagged or removed. [SOC 2: CC2.1, C1.1]

3. Production and non-production resources shall be separated by account, so that scope can be established by account boundary rather than by inspection. [SOC 2: CC5.2, CC6.3]
4. Resources that no longer have an owner, a purpose or recent use shall be decommissioned. Idle infrastructure is both a cost and an unmonitored attack surface. [SOC 2: CC2.1, CC6.6]
5. Storage volumes, snapshots and backups shall be inventoried alongside compute, since they persist after the resource that created them is gone. [SOC 2: CC2.1, C1.2]

9 Software, SaaS and Shadow IT

At this size, most unmanaged risk arrives through someone connecting a useful tool rather than through a procurement decision. Detection is more effective than prohibition.

1. Third-party application access to the Company identity provider and productivity suite shall be restricted by allow-list, so that connecting a new application requires approval rather than a click. [SOC 2: CC6.1, CC9.2]
2. Connected applications shall be reviewed periodically, and at least annually for the Company's current size, with higher-risk or newly introduced services reviewed when added. Unapproved material services shall be removed or evaluated under the Vendor Management Policy. [SOC 2: CC9.2, CC6.3]
3. Software and subscription expenditure shall be reconciled periodically against the inventory, since an unmanaged service usually appears on a card statement before it appears anywhere else. [SOC 2: CC2.1, CC9.2]
4. Only licensed and supported software shall be used for Company work, and software at end of support shall be upgraded, replaced or removed. [SOC 2: CC7.1, CC2.1]
5. Personnel shall not adopt a service for Company or client information without it being assessed and added to the inventory. [SOC 2: CC1.1, CC9.2]

10 Media Handling and Secure Disposal

Assets leave the Company more often than they arrive, and disposal is where information is most easily lost.

1. Media and devices holding Company or client information shall be sanitised or destroyed before disposal, reassignment or return to a lessor, and the action recorded. [SOC 2: CC6.5 • HIPAA §164.310(d)(2)(i), (ii) • GDPR Art. 32]
2. Cloud storage disposal shall rely on the provider's deletion mechanisms and the shared responsibility position, rather than on a physical destruction process the Company does not perform. [SOC 2: CC6.5]
3. Removable media shall not be used for Company or client information other than by exception with a recorded justification. [SOC 2: CC6.7, C1.1]
4. Disposal records shall be reconciled against the inventory so that an asset marked disposed is confirmed as no longer present. [SOC 2: CC6.5, CC2.1]

- 169 5. Backups and snapshots holding information subject to a deletion commitment shall be identified,
170 and the retention that applies to them stated honestly to clients. [SOC 2: C1.2 · GDPR Art. 17]

11 Asset Return and Offboarding

171 Departures are where assets and the information on them go missing, particularly in a distributed team.

- 172 1. Company-owned equipment shall be returned on departure, and its return recorded against the
173 inventory entry. [SOC 2: CC6.5, CC6.2 · HIPAA §164.310(d)(1)]
- 174 2. Where Company equipment is not returned within a reasonable period, access from it is revoked,
175 the non-return is recorded and the matter is treated as a security event. The Company wipes the
176 device only where it is technically able to do so; it does not rely on being able to. [SOC 2: CC6.5, CC7.3]
- 177 3. Company data shall be removed from personally owned devices at departure, and the removal
178 confirmed by the departing individual and recorded. [SOC 2: CC6.5, C1.2 · GDPR Art. 17]
- 179 4. Assets owned by a departing person — including cloud resources, repositories, agents and service
180 accounts — shall be reassigned before their access is removed, so that no asset is left without an
181 owner. [SOC 2: CC2.1, CC6.2]

12 Asset Records and Evidence

182 The records below are produced by the controls above and are what a service auditor will sample.

- 183 1. The current asset inventory with owner, classification and source. [SOC 2: CC2.1]
- 184 2. The annual asset and device review record, including confirmation against the current personnel
185 list and any material discrepancies identified. [SOC 2: CC2.1, CC6.8]. The device record and annual
186 personnel acknowledgement or other available evidence supporting the applicable endpoint
187 baseline. [SOC 2: CC6.4, CC6.8]. Periodic connected-application review records, at least annually
188 unless risk requires a more frequent review. [SOC 2: CC9.2]. Where Company-provided
189 equipment is used, records of its issue, applicable protection, return and sanitisation. [SOC 2:
190 CC6.8, CC6.5]
- 191 3. The device record, and the annual attestations covering encryption, screen lock, updates and
192 platform protection. [SOC 2: CC6.4, CC6.8]
- 193 4. Annual connected-application review records. [SOC 2: CC9.2]
- 194 5. Disposal, return and deletion-confirmation records reconciled to inventory entries. [SOC 2: CC6.5]
- 195 6. Where Company-provided equipment is in use, the record of its issue, its endpoint protection and
196 its return or sanitisation. [SOC 2: CC6.8, CC6.5]

13 Enforcement

- 197 1. Violations of this policy may result in disciplinary action up to and including termination of
198 employment or engagement, and, where applicable, civil or criminal referral. [SOC 2: CC1.5]

2. Disciplinary decisions shall be documented by the Security Officer and applied consistently, in accordance with the Company's personnel sanctions process. [SOC 2: CC1.5]

14 Exceptions

Exceptions to this policy must be requested in writing to the Security Officer and approved by the Information Security Steering Committee before taking effect. Approved exceptions shall be documented, risk-assessed, time-bound with an expiry date, and reviewed at least annually.

15 Reference

1. SOC 2 Trust Services Criteria, Security category [CC2.1, CC5.2, CC6.1, CC6.5, CC6.8, CC7.1, CC9.2]
2. POL-ISP-001 Information Security Policy [SOC 2: CC5.3, CC4.2]
3. POL-AC-001 Access Control Policy [SOC 2: CC6.1, CC6.3]
4. POL-NET-001 Network Security Policy [SOC 2: CC5.2, CC6.6]
5. POL-VPM-001 Vulnerability and Patch Management Policy [SOC 2: CC7.1]
6. POL-DCL-001 Data Classification Policy [SOC 2: CC2.1]
7. POL-DRD-001 Data Retention and Disposal Policy [SOC 2: CC6.5]
8. POL-VM-001 Vendor Management Policy [SOC 2: CC9.2]
9. POL-LOG-001 Logging and Monitoring Policy [SOC 2: CC7.2]
10. POL-COC-001 Code of Conduct [SOC 2: CC1.1, CC1.4]
11. HIPAA Security Rule, 45 CFR §164.310(c) and §164.310(d)
12. EU General Data Protection Regulation, Articles 5, 17, 30 and 32

16 DOCUMENT POLICY HISTORY

Version	Date	Description
1.0	July 23, 2026	Initial policy release